INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GRC)

Course: GRC102 - Information Security Governance

Lab 3B: Quantitative Risk Assessment and Control Selection

Student Name: Jackline Maina

Reg. No: C11/26/CGRCE/17588

Date: 01/11/2026

Contents

Executive Summary 3

2. Introduction 5

3. Quantitative Risk Analysis 7

4. Risk Prioritization Matrix 8

6. Control Evaluation 9

7. Cost-Benefit Analysis 12

8. Project Implementation Plan 13

9. Dashboard Visualizations 14

10. Recommendations 16

11. Conclusion 17

12. References 17

Executive Summary

SecureBank Financial recently conducted a penetration test and vulnerability assessment of its SecureMobile banking platform, which serves 500,000 active customers and processes approximately 50,000 transactions daily with an average transaction value of $2,500.

The assessment identified three critical vulnerabilities that could significantly impact the confidentiality, integrity, and availability of customer financial services. These vulnerabilities include an API Authentication Bypass affecting the transaction processing system, a Database Injection vulnerability affecting customer information, and a Session Hijacking vulnerability that could facilitate account takeover attacks.

Quantitative risk analysis was performed using the Annualized Loss Expectancy (ALE) methodology to estimate the organization's annual financial exposure. The analysis revealed that the Database Injection vulnerability presents the highest risk to the organization, with an ALE of $31.25 million, due to the potential compromise of 500,000 customer records and associated regulatory, notification, and remediation costs. The Session Hijacking vulnerability presents an ALE of $3 million, while the API Authentication Bypass vulnerability presents an ALE of $750,000.

To mitigate these risks, three security controls were evaluated: an Advanced API Security Gateway, a Web Application Firewall (WAF), and a Multi-Factor Authentication (MFA) Enhancement. Based on cost-benefit analysis, the Web Application Firewall provides the greatest overall reduction in organizational risk exposure and delivers the highest return on investment, while MFA Enhancement provides substantial protection against account takeover attacks. The API Security Gateway effectively reduces unauthorized transaction risks associated with API exploitation.

Based on the findings of this assessment, it is recommended that SecureBank Financial prioritize the implementation of the Web Application Firewall, followed by Multi-Factor Authentication Enhancement, and subsequently deploy the Advanced API Security Gateway. This approach provides the greatest reduction in annualized financial loss while maximizing the value derived from security investments.

Key Findings

- Platform assessed: **SecureMobile Banking Platform** (500,000 customers)
- Highest risk: **Database Injection Vulnerability** (ALE: **$31.25M**)
- Total annual risk exposure: **$35M**
- Best performing control: **Web Application Firewall (WAF)**
- Recommended implementation approach:



2. Introduction

Objective

The objective of this assessment is to quantify cybersecurity risks using established quantitative risk analysis methods and evaluate security controls based on financial impact and return on investment.

Scope

Include:

- API Authentication Bypass
- Database Injection
- Session Hijacking

Risk Assessment Methodology

Single Loss Expectancy (SLE)
SLE estimates the financial loss from a single successful security incident.

Formula:

SLE = Asset Value × Exposure Factor

Where:

- Asset Value (AV) = Value of the affected asset.
- Exposure Factor (EF) = Percentage of loss resulting from the incident.

Annual Rate of Occurrence (ARO)
ARO measures the estimated frequency at which a threat is expected to occur within one year.

Examples:

- 1.0 = Once per year
- 0.5 = Once every two years
- 0.25 = Once every four years

Annualized Loss Expectancy (ALE)
ALE estimates the expected annual financial loss associated with a specific risk.

Formula:

ALE = SLE × ARO

ALE helps organizations quantify risk in monetary terms, prioritize remediation efforts, and justify security investments. Higher ALE values indicate greater financial risk and should be prioritized for mitigation.

3. Quantitative Risk Analysis

Finding 1: API Authentication Bypass

Scenario

The mobile banking API contains an authentication weakness that could allow attackers to bypass access controls and perform unauthorized transactions. Successful exploitation may result in financial losses, fraud, regulatory penalties, and reputational damage.

Calculations

Metric	Value
SLE	$5,000,000
ARO	0.15
ALE	$750,000

Interpretation

The estimated annual loss exposure is **$750,000**. Although the likelihood of occurrence is relatively low, the potential impact of a successful attack is significant, making this a medium-priority risk that requires remediation.

Finding 2: Database Injection

Scenario

A database injection vulnerability could allow attackers to access or manipulate customer records stored within the SecureMobile banking platform. This may lead to data breaches, regulatory fines, legal liabilities, and loss of customer trust.

Calculations

Metric	Value
SLE	$125,000,000
ARO	0.25
ALE	$31,250,000

Interpretation

With an ALE of **$31.25 million**, this represents the highest risk identified during the assessment. The combination of a high-impact data breach and a realistic likelihood of occurrence makes this the organization's most critical security concern.

Finding 3: Session Hijacking

Scenario

The application is vulnerable to session hijacking attacks, enabling unauthorized users to take control of legitimate customer sessions. This could result in unauthorized account access, fraudulent transactions, and customer account compromise.

Calculations

Metric	Value
SLE	$7,500,000
ARO	0.40
ALE	$3,000,000

Interpretation

The ALE of **$3 million** indicates a substantial annual risk. While the potential loss is lower than that of the database injection vulnerability, the higher likelihood of occurrence makes this a high-priority risk requiring prompt mitigation.

4. Risk Prioritization Matrix

The identified vulnerabilities were ranked based on their **Annualized Loss Expectancy (ALE)** values. Risks with higher ALE values represent a greater potential financial impact on the organization and should therefore receive higher remediation priority. This approach enables SecureBank Financial to focus its resources on addressing the most significant threats first.

Vulnerability	ALE	Priority
Database Injection	$31,250,000	Critical
Session Hijacking	$3,000,000	High

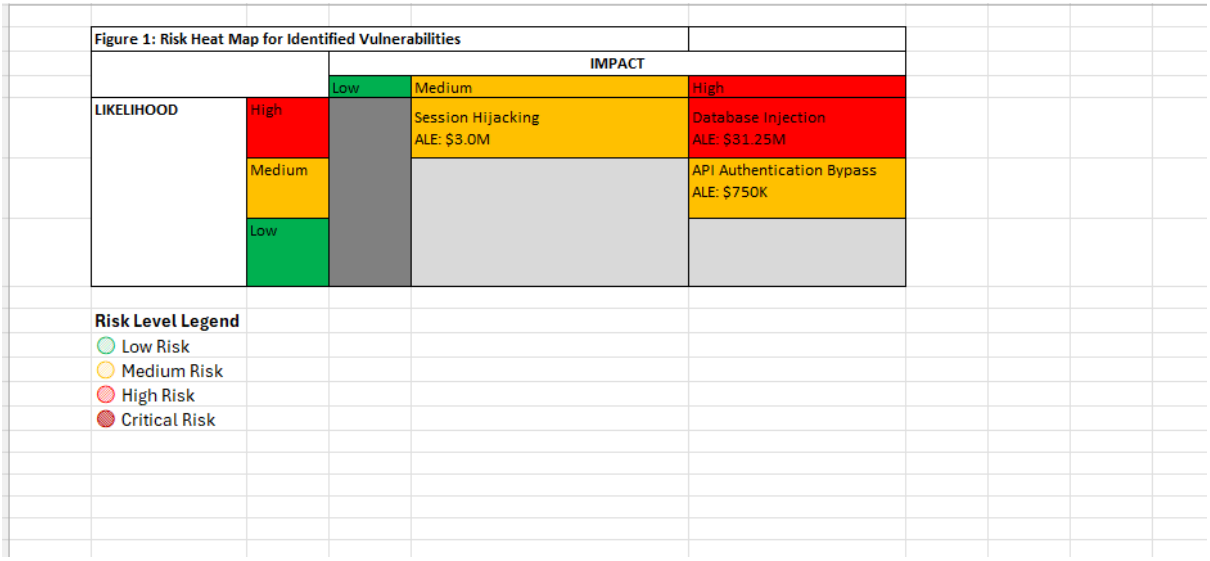
Vulnerability	ALE	Priority
API Authentication Bypass	$750,000	Medium

Database Injection is the highest-priority risk due to its potential to expose sensitive customer information and result in substantial financial, legal, and reputational losses. **Session Hijacking** is classified as a high-priority risk because of its relatively high likelihood of occurrence and potential to facilitate unauthorized account access. Although **API Authentication Bypass** has the lowest ALE, it still presents a significant security concern and should be addressed as part of the organization's remediation strategy.

Risk Heat Map

The risk heat map provides a visual representation of the identified risks based on their likelihood of occurrence and potential business impact. It enables management to quickly identify areas requiring immediate attention and supports risk-based decision-making.

Figure 1: Risk Heat Map for Identified Vulnerabilities



The heat map illustrates that **Database Injection** falls within the highest-risk region due to its severe business impact and significant likelihood of occurrence. **Session Hijacking** presents a high-risk exposure because of its elevated occurrence rate, while **API Authentication Bypass** remains a medium-level risk requiring mitigation but posing comparatively lower annual financial exposure.

6. Control Evaluation

The following security controls were evaluated to determine their effectiveness in reducing risk exposure, implementation costs, and overall return on investment

(ROI). The objective is to identify the controls that provide the greatest reduction in annualized loss while remaining financially viable for SecureBank Financial.

6.1 API Security Gateway

An API Security Gateway provides centralized protection for application programming interfaces by enforcing authentication, authorization, traffic inspection, and threat detection. This control is designed to mitigate unauthorized access and transaction manipulation resulting from API Authentication Bypass vulnerabilities.

Cost Analysis

Item	Cost
Initial Setup	$350,000
Annual Maintenance	$50,000
Total Cost	**$400,000**

Benefit Analysis

Metric	Value
Risk Reduction	$675,000
ROI	68.75%
Payback Period	0.59 Years

Evaluation

The API Security Gateway reduces the organization's annual exposure to API-related attacks by approximately **90%**, lowering the potential financial impact associated with unauthorized transactions and system misuse. While the control has the highest implementation cost among the evaluated solutions, it provides a positive ROI and recovers its investment within the first year of deployment. This makes it a valuable long-term security investment, particularly for protecting critical banking APIs.

6.2 Web Application Firewall (WAF)

A Web Application Firewall (WAF) helps protect web applications from common attacks such as SQL Injection, Cross-Site Scripting (XSS), and malicious web requests. In this assessment, the WAF primarily addresses the risks associated with Database Injection attacks while also providing additional protection for web-facing APIs.

Cost Analysis

Item	Cost
Initial Setup and Maintenance	$175,000

Benefit Analysis

Metric	Value
Risk Reduction	$24,000,000
ROI	13,614%

Evaluation

The WAF delivers the highest risk reduction of all evaluated controls, reducing potential annual losses by approximately **$24 million**. In addition, it has the lowest implementation cost and produces an exceptionally high ROI. Given the severe financial impact associated with database compromise, deployment of a WAF provides immediate business value and represents the most cost-effective control for reducing organizational risk.

6.3 Multi-Factor Authentication (MFA) Enhancement

Multi-Factor Authentication strengthens user authentication by requiring additional verification factors beyond passwords. This significantly reduces the likelihood of account compromise and unauthorized session access.

Cost Analysis

Item	Cost
Initial Setup and Maintenance	$230,000

Benefit Analysis

Metric	Value
Risk Reduction	$2,850,000
ROI	1,139%

Evaluation

The MFA enhancement mitigates approximately **95%** of the risks associated with Session Hijacking and account takeover attacks. Although it offers a lower overall risk reduction than the WAF, its implementation cost is relatively low and the resulting ROI remains highly favorable. MFA also improves customer account security and supports compliance with industry security best practices.

Summary of Control Evaluation

Control	Cost	Risk Reduction	ROI	Priority
Web Application Firewall	$175,000	$24,000,000	13,614%	1
MFA Enhancement	$230,000	$2,850,000	1,139%	2
API Security Gateway	$400,000	$675,000	68.75%	3

The analysis indicates that the **Web Application Firewall (WAF)** provides the greatest reduction in annual risk exposure and delivers the highest return on investment. Therefore, it should be prioritized for implementation, followed by the **MFA Enhancement** and the **API Security Gateway**. This approach maximizes risk reduction while ensuring efficient use of security investment funds.

7. Cost-Benefit Analysis

A cost-benefit analysis was conducted to compare the financial effectiveness of the proposed security controls. The analysis considered implementation and maintenance costs, expected reduction in annualized loss exposure, and return on investment (ROI). This enables management to prioritize controls that provide the greatest risk reduction while optimizing security expenditure.

Control	Cost	Risk Reduction	ROI
Web Application Firewall (WAF)	$175,000	$24,000,000	13,614%

MFA Enhancement	$230,000	$2,850,000	1,139%
API Security Gateway	$400,000	$675,000	68.75%

Analysis

The **Web Application Firewall (WAF)** provides the highest value among the evaluated controls. Despite its relatively low implementation cost, it delivers a substantial reduction in annual risk exposure and achieves the highest ROI. This makes it the most financially beneficial control for mitigating the organization's most significant risk, Database Injection.

The **MFA Enhancement** also demonstrates strong cost-effectiveness. By significantly reducing the likelihood of account takeover and session hijacking attacks, it provides a substantial decrease in annual loss exposure while maintaining a favorable ROI.

The **API Security Gateway** provides important protection for API-based attacks and unauthorized transactions. Although its implementation cost is the highest of the three controls and its ROI is comparatively lower, it remains a worthwhile investment due to its ability to strengthen security around critical banking APIs.

Overall, the analysis indicates that implementing the WAF first would provide the greatest immediate reduction in organizational risk, followed by MFA Enhancement and the API Security Gateway.

8. Project Implementation Plan

To minimize implementation risks and ensure efficient deployment of security controls, a phased implementation approach is recommended. The proposed timeline prioritizes controls that provide the greatest reduction in annual risk exposure while allowing adequate time for testing and validation.

Activity	Week 1	Week 2	Week 3	Week 4
Procure WAF	■			
Deploy WAF		■		
MFA Upgrade		■	■	
API Gateway Deployment			■	■

Security Testing & Validation				

Implementation Approach

During **Week 1**, the organization will procure and configure the Web Application Firewall. In **Week 2**, the WAF will be deployed to protect internet-facing applications and APIs from common web-based attacks.

The **MFA Enhancement** project will begin in Week 2 and continue into Week 3 to allow sufficient time for user enrollment, configuration, and validation. Implementation of the **API Security Gateway** will then take place during Weeks 3 and 4 to strengthen authentication and authorization controls across banking APIs.

Following deployment, comprehensive testing will be performed to verify that all controls are functioning as intended and effectively mitigating the identified risks.

9. Dashboard Visualizations

To assist management in understanding the organization's cyber risk posture, an executive dashboard was developed to visually present key risk metrics and financial analysis results.

Dashboard Page 1: Executive Overview

The Executive Overview dashboard provides a high-level summary of the organization's current risk exposure and recommended remediation priorities.

KPI Cards

KPI	Value
Total ALE	$35,000,000
Highest Risk	Database Injection
Best ROI	WAF (13,614%)

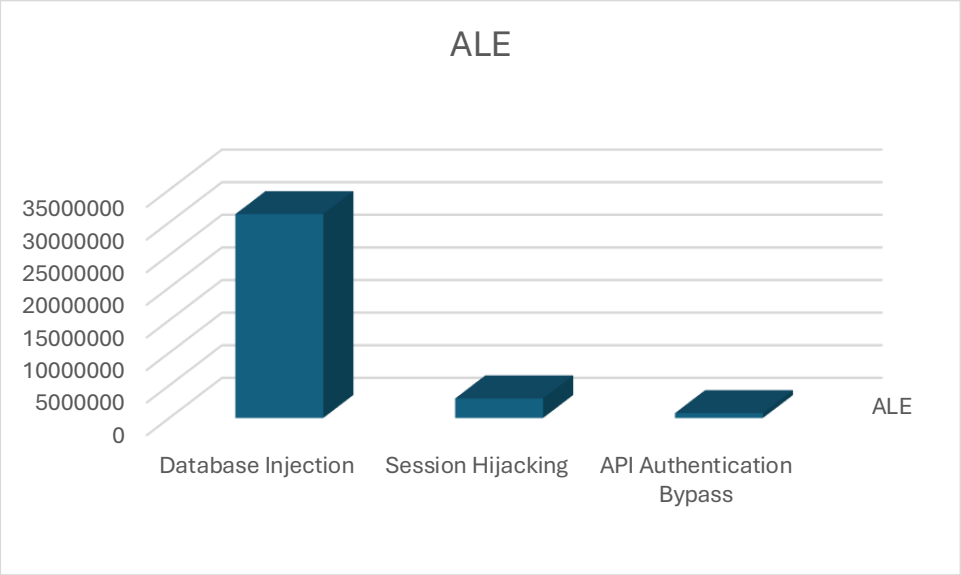
These indicators allow executives to quickly identify the organization's primary risks and the controls that provide the greatest business value.

Dashboard Page 2: Risk and Control Analysis

The second dashboard page provides detailed visualizations supporting risk-based decision-making.

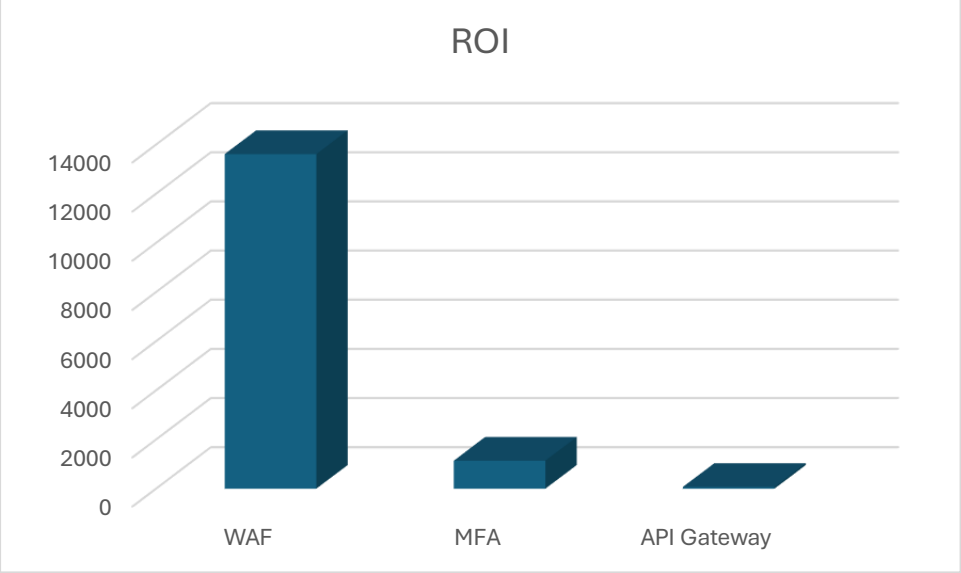
ALE by Risk

A bar chart comparing the annualized loss expectancy for each identified vulnerability.



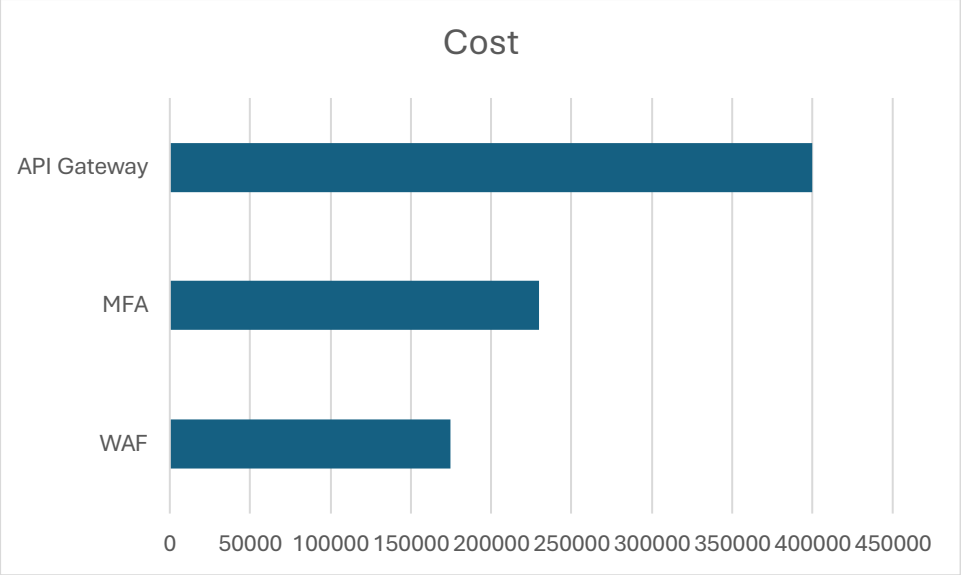
ROI Comparison

A bar chart comparing the return on investment achieved by each proposed security control.



Control Cost Comparison

A chart illustrating the implementation and maintenance costs associated with each security control.



Dashboard Benefits

The dashboard transforms technical risk data into business-focused metrics that can be easily understood by executive stakeholders. It supports risk prioritization, investment planning, and ongoing security governance by providing clear and actionable insights.

10. Recommendations

Based on the quantitative analysis, risk prioritization, and cost-benefit assessment, the following implementation sequence is recommended.

Priority 1: Implement Web Application Firewall (WAF)

The WAF should be deployed immediately due to its ability to mitigate the organization's highest-risk vulnerability, Database Injection. It provides the greatest reduction in annual loss exposure while delivering the highest return on investment.

Priority 2: Implement MFA Enhancement

Following WAF deployment, MFA should be enhanced to reduce the risk of unauthorized account access and session hijacking attacks. This control significantly improves customer account security and provides strong financial returns.

Priority 3: Deploy API Security Gateway

The API Security Gateway should be implemented to strengthen authentication and authorization controls for API communications. Although it has the highest

implementation cost, it provides important long-term protection for critical banking services and transactions.

Recommended Strategy

By implementing controls in this order, SecureBank Financial can achieve the maximum reduction in risk exposure while ensuring efficient utilization of security resources and budget.

11. Conclusion

This quantitative risk assessment identified Database Injection, Session Hijacking, and API Authentication Bypass as significant security risks affecting SecureBank Financial's SecureMobile platform. Analysis of Annualized Loss Expectancy (ALE) revealed that Database Injection represents the greatest financial threat, with an estimated annual exposure of $31.25 million. Evaluation of proposed security controls demonstrated that the Web Application Firewall (WAF) offers the highest reduction in risk exposure and the greatest return on investment, making it the most effective immediate mitigation measure. The implementation of MFA Enhancement and an API Security Gateway will further strengthen the organization's security posture by reducing the likelihood of account compromise and unauthorized API access. Adopting the recommended implementation strategy will significantly reduce annual financial losses, improve regulatory compliance, and enhance the protection of customer information and banking services.

12. References

- NIST SP 800-30
- NIST Cybersecurity Framework
- Course materials
- Lecture notes